

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

RABIATU UMAR AHMAD

C11/26/CGRCE/17569

COHORT 11

25th September, 2026

TASK 1: GOVERNANCE ARCHITECTURE AND STAKEHOLDER MAP

1. Governance Gap Assessment

The organisation TechGlobal has about 2,500 employees in five global offices. The security governance of TechGlobal is mainly controlled by the IT Director. This causes several weaknesses.

Weakness	Consequences
Too much power is concentrated within the IT	One person or department may make security, risk and operational decisions without enough independent review.
No clear escalation process	Serious cyber risks may remain at operational level for too long.
No formal security governance committee	Important security issues may not be discussed by business, legal, finance and risk stakeholders

2. Stakeholder Map

Stakeholder	Authority / Influence	Main Interest	Information Needed	Contribution
Board	Very high	Risk appetite, reputation and assurance	Major cyber risks and incidents	Provides oversight
CEO	Very high	Business performance and strategic risk	Executive risk reports	Provides executive accountability
CISO	High	Security strategy and governance	Security performance and risks	Leads security governance
CRO/Risk	High	Enterprise risk management	Risk assessments and treatment	Coordinates risk management
Legal	High	Legal and regulatory compliance	Incidents, contracts and privacy issue	Provides legal advice
Finance	High	Budget and financial risk	Security costs and losses	Supports investment decisions
HR	Medium	Employee security and conduct	Joiner/mover/leaver information	Supports people controls
IT	High	Technology operations	Technical risks and control status	Implements technical

				controls
Business Unit	medium	Business operations	Local security risks	Own business risks and controls

3. Proposed Security Governance Organisation Structure

Board of Directors



CEO / Executive Management



Executive Security Council



CISO + CRO/Risk + Legal + Finance + HR + IT + Business Representatives



Security Governance / Steering Committee



Security Teams + IT + Business Units + Specialised Working Groups

4. Consultant Justification

I recommend this structure because TechGlobal is a large organisation with approximately 2,500 employees in five global offices. The current IT-centred approach is not adequate because cybersecurity the whole organization is affected by cybersecurity, not only IT.

The above structure separates oversight, risk management and technical implementation. It also forms formal communication between operational teams, management and the Board.

The Security Governance Committee will allow different departments to discuss security issues together. Serious risks can then be escalated to executive management and the Board when necessary.

This structure should improve accountability, reduce conflicts of interest and provide better visibility of cyber risks.

Task 2 Governance Responsibility and Authority Matrix

1. Cross-functional Governance Responsibility Matrix

Role	Purpose	Main	Decision	Reports
------	---------	------	----------	---------

		Responsibilities	Authority	
Board	Provide oversight	Risk appetite, major risk oversight, assurance	Approves major risk appetite	Receives reports from CEO
CEO	Executive accountability	Business alignment and strategic decisions	Approves major business decisions	Board
CISO	Lead security governance	Security strategy, policies, security reporting	Security governance decisions within mandate	CEO / Executive Council
CRO/Risk	Enterprise risk integration	Risk assessment, treatment and aggregation	Risk methodology and challenge	CEO/Board risk reporting
Legal	Legal and regulatory advice	Privacy, contracts, notification and compliance	Legal advice and regulatory decisions within mandate	CEO/CISO
Finance	Financial governance	Budget, investment and financial controls	Security budget recommendations	CEO/Board
HR	People governance	Awareness, employee controls, disciplinary processes	HR-related decisions	CEO
IT	Technology delivery	Technical controls and secure operations	Technical implementation	CISO/IT leadership

2. Authority Conflicts and Resolution

i. CISO and IT

The CISO may decide what security controls are required while IT is responsible for implementing them.

Resolution: CISO sets security requirements and IT implements approved technical controls.

ii. CISO and CRO/Risk

Both may be involved in cybersecurity risk.

Resolution: The CISO provides security risk information while CRO/Risk provides the enterprise risk methodology and independent challenge.

iii. Business Unit and CISO

A Business Unit may want to accept a security risk to meet a business deadline.

Resolution: The Business Unit explains the business impact, but risk acceptance must follow the approved risk authority and escalation process.

TASK 3: SECURITY GOVERNANCE COMMITTEE ECOSYSTEM

1. Committee structure

- CEO – Chair
- CISO
- CRO/Risk
- Legal
- Finance
- HR
- IT
- Business Unit

2. Security Governance Committee

They handle regular cross-functional security governance. And their responsibilities include

- Review security performance.
- Review security policies.
- Monitor risk treatment.
- Review compliance issues.

3. Sample committee agenda

- Opening and confirmation of previous minutes
- Review of outstanding actions
- Cyber-risk dashboard
- Major security incidents
- Security policy updates
- Vulnerability management
- Compliance and regulatory matters
- Security projects and budget
- Business Unit security issues
- Decisions required

- Escalations to Executive Security Council
- Any other business

Task 4 RACI Accountability Matrix

R = Responsible

A = Accountable

C = Consulted

I = Informed

Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT	BU
Cybersecurity strategy approval	I	A	R	C	C	I	I	C	C
Security policy approval	I	A	RI	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	I	R	A	C	I	I	C	C
Risk acceptance	A	A	C	R	C	I	I	C	R
Security budget approval	I	I	R	C	I	R	I	C	C
Third-party security review	I	I	A	C	C	I	I	R	C
Access governance	I	I	A	C	I	I	C	R	C
Incident response governance	I	A	R	C	C	I	C	R	C
Incident response escalation	I	A	R	C	C	I	I	R	C
Regulatory notification decision	I	A	C	C	R	I	I	C	I
Security	I	I	A	C	C	I	R	C	C

awareness I programme									
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity / recovery governance	I	A	C	R	C	C	C	R	C
Board cyber- risk reporting	A	R	R	C	C	C	I	C	I

3. Implementation guide

The RACI Matrix should be used by managers in planning projects, approving controls and responding to incidents. The manager should identify the Responsible and Accountable roles before starting an activity. The RACI Matrix should be used to avoid delays and confusion during an incident.

TASK 5: CYBER-RISK ESCALATION AND SEGREGATION OF DUTIES

1. Major Cyber-Risk Escalation Workflow

Detection/Identification

↓

Initial assessment by operational/security team

↓

Classify risk level

↓

Level 1 – Operational Response

↓

If risk exceeds operational authority

↓

Level 2 – Executive Escalation

↓

If risk is material to the organisation



Level 3 – Material Risk / Board Escalation



Decision and treatment



Record decision and actions



Monitor and close

2. Escalation Threshold

Level Decision	Example Trigger	Authority	Notification	Response
Level 1 – Operational	Limited security issue with low business impact	Security/IT management	Relevant operational teams	Immediate operational response
Level 2 – Executive	Significant incident, major service disruption or serious regulatory concern	CEO/Executive Council	Senior management	Rapid executive response
Level 3 – Material/Board	Major business impact, material financial/regulatory/reputational exposure	CEO and Board according to governance authority	Board and required stakeholders	Immediate executive/Board oversight

3. Decision Recording and Assurance

All significant governance decisions should be recorded in a decision log. This creates an audit trail and makes it easier to determine who made a decision, why it was made and whether the required actions were completed.